```
Cache-Control: private, max-age=0
Strict-Transport-Security: max-age=31536000
Server:
Transfer-Encoding: chunked

{"author":"demo","time":"2019-02-
06T15:15:03.138Z","message":"Hello,
World!","uri":"/spaces/1/messages/1"}
```

### 3.6.5 Avoiding privilege escalation attacks

It turns out that the demo2 user we just added can do a bit more than just reading messages. Because we allow any user to add new users to the space, and they can choose the permissions for the new user, demo2 can simply add a new account for themselves with more permissions than we originally have them, as shown in the following example:

```
$ curl --cacert server.pem -H 'Content-Type:
application/json'
[CA]-d '{"username":"evildemo2","password":"password"}'
[CA]https://localhost:4567/users
[CA]{"username":"evildemo2"}
$ curl --cacert server.pem -u demo2:password
[CA]-H 'Content-Type: application/json'
[CA]-d '{"username":"evildemo2","permissions":"rwd"}'
[CA]https://localhost:4567/spaces/1/members
{"permissions":"rwd","username":"evildemo2"}
$ curl -i -X DELETE --cacert server.pem -u evildemo2:password
[CA]https://localhost:4567/spaces/1/messages/1
HTTP/1.1 200 OK
Date: Wed, 06 Feb 2019 16:21:29 GMT
Content-Type: application/json
```